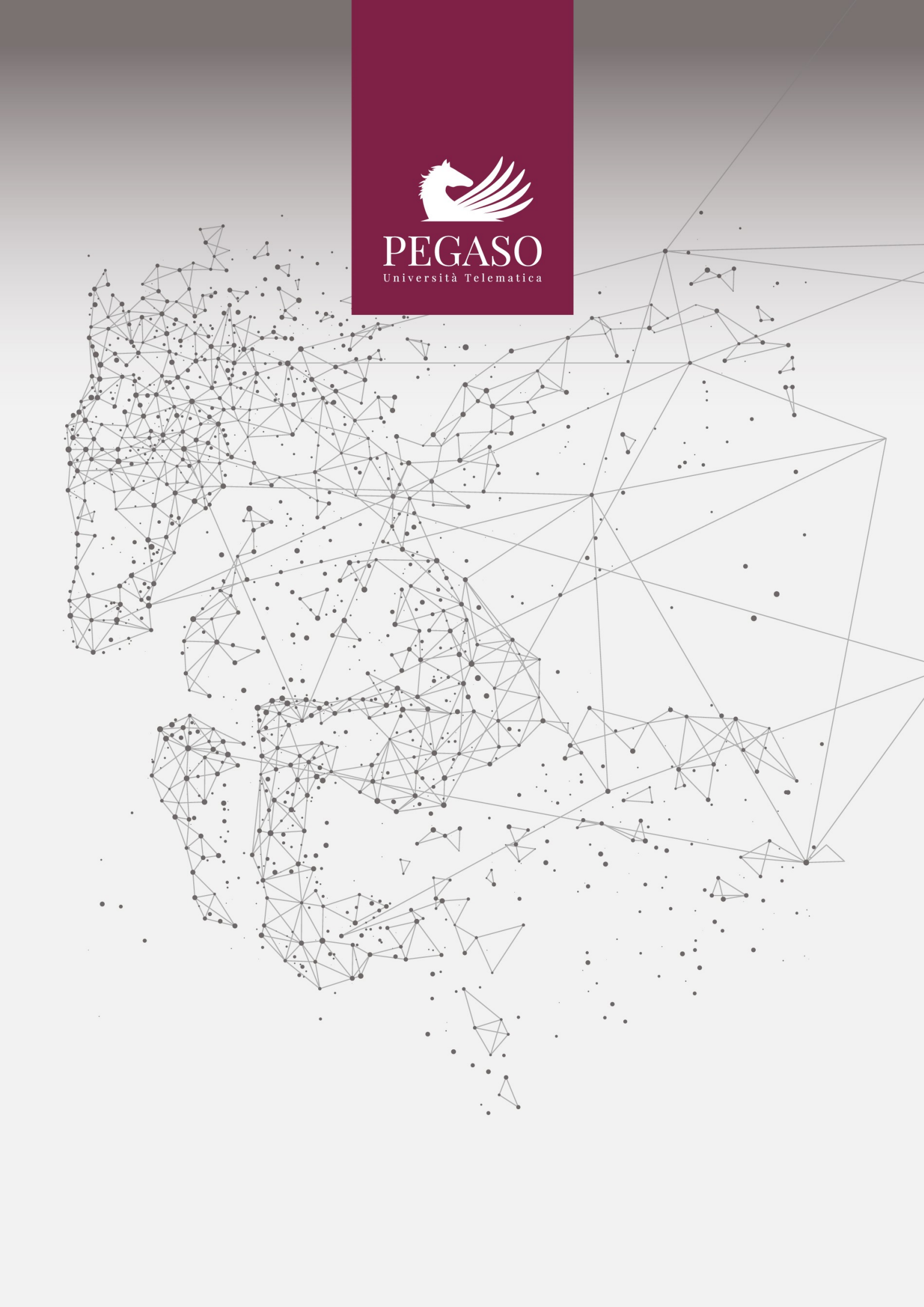

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 I WORM 3

2 ALTRE TIPOLOGIE DI MALWARE 5

2.1 BOMBA LOGICA 5
2.2 CAVALLI DI TROIA (TROJAN) 5
2.3 BACKDOOR (TRAPDOOR) 5
2.4 ROOTKIT 6
2.5 KEYLOGGER 6
2.6 SPYWARE (PHISHING) 6
2.7 BOT (ROBOT), ZOMBIE 7
2.8 SPAM 7
2.9 EXPLOIT 7
2.10 RANSOMWARE 8

3 ATTACCHI DDOS 9

BIBLIOGRAFIA 12

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 I worm

Un *worm* è un programma che in maniera attiva ricerca altri computer da infettare e ogni computer infettato serve da trampolino di lancio automatico per attaccare altre macchine. I worm di solito utilizzano alcune vulnerabilità presenti nei programmi che girano su client o server per accedere al sistema e usano le connessioni di rete per diffondersi molto rapidamente ma lo possono fare anche attraverso la condivisione di media digitali.

I worm, una volta attivati, si propagano in maniera continuativa e svolgono azioni dannose sui sistemi dove si sono impiantati; per diffondersi essi usano dei meccanismi per accedere ai sistemi remoti come ad esempio:

- Posta elettronica e sistemi di messaggistica: il worm invia messaggi che lo contengono come allegato
- La condivisione di file (USB drive)
- Funzionalità di esecuzione remota
- Funzionalità di login remoto
- Funzionalità di trasferimento file da remoto

La propagazione del worm comincia con una fase di «scansione» della rete alla ricerca di altri sistemi da infettare; tale scansione può avvenire:

- *Random*: ogni host infettato prova indirizzi IP casualmente (uso di seed differenti)
- *Hit list*: l'attaccante crea una lista di potenziali macchine vulnerabili e ogni macchina infetta tenta una porzione di tale lista
- *Topologico*: il worm usa le informazioni di rete contenute nel sistema infettato per trovare altre macchine
- *Sottorete locale*: se un host è infettato internamente (dietro il firewall) allora può cercare di infettare i computer che si trovano nella rete locale

Le principali caratteristiche dei worm sono le seguenti:

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- *Multipiattaforma*
- *Multi-exploit*: penetrano nei sistemi in differenti modalità sfruttando lacune nei server web, nei browser, nei server di posta, ecc.
- *Diffusione rapidissima*: si usano varie tecniche per riuscire a infettare più sistemi vulnerabili possibili nel minor tempo
- *Polimorfismo*: come i virus, ogni copia viene rigenerata dinamicamente (forma diversa ma stesse funzionalità)
- *Metamorfismo*: non cambia solo l'apparenza ma anche il comportamento a seconda dello stadio di propagazione a cui ci si trova
- *Mezzi di trasporto*: i worm, grazie alle loro capacità di attacco rapido, possono essere utilizzati per diffondere altre tipologie di malware

Exploit «giorno zero»: per ottenere il massimo effetto sorpresa, i worm sfruttano alcune lacune di sicurezza sconosciute che diventano note pubblicamente solo al lancio del worm.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2 Altre tipologie di malware

In questo paragrafo sono riportate alcune delle tipologie più note di malware descrivendone sommariamente le caratteristiche principali; ovviamente questa rassegna non vuol essere esaustiva dell'argomento.

2.1 Bomba logica

La *Bomba Logica* rappresenta il componente chiave dei malware. Con tale termine si indica proprio il codice incorporato nel malware e programmato per attivarsi al verificarsi di certe condizioni (e.g. presenza di certi file, una data, un orario, ecc.). Una volta scattata, la bomba logica può modificare o cancellare dei file, bloccare la macchina e così via.

2.2 Cavalli di Troia (Trojan)

Il Cavallo di Troia o Trojan è un programma o una procedura utile o apparentemente utile (per esempio un gioco o un programma che si adopera normalmente), contenente un codice nascosto che, una volta richiamato, svolge operazioni dannose. Può essere usato per svolgere indirettamente funzioni che l'attaccante non sarebbe autorizzato a compiere (accesso a file di un altro utente, scanning di credenziali bancarie). Il Cavallo di Troia essendo incorporato in un gioco o in un software di uso comune, di solito, approfitta della consuetudine dell'utente nell'utilizzare un determinato programma.

2.3 Backdoor (Trapdoor)

Il Backdoor è un punto di accesso segreto in un programma che permette di entrare in un sistema evitando le normali procedure di sicurezza (e.g. accesso diretto programmatore mediante

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

una sequenza complessa di comandi di input). La Backdoor è di solito implementata come un servizio di rete che ascolta su una porta non standard a cui l'attaccante può connettersi per effettuare azioni dannose.

2.4 Rootkit

Il Rootkit rappresenta un insieme di programmi che un hacker può installare su un sistema per mantenere coperto il suo illecito accesso a quel sistema con privilegi di amministratore (root). Una volta effettuato l'accesso da amministratore, l'hacker ha completo controllo del sistema, dei file e del traffico di rete.

2.5 Keylogger

I Keylogger sono solitamente usati per il furto di credenziali o informazioni sensibili. Il Keylogger viene installato su un computer con l'intento di catturare i caratteri inseriti da tastiera, per esempio login e password oppure il numero della carta di credito. Inoltre, per evitare che l'attaccante riceva inutilmente tutto il testo che viene inserito, il Keylogger può essere dotato di filtri così da estrarre solo informazioni collegate a certe parole chiave o indirizzi web come PayPal, Visa, ecc.

2.6 Spyware (phishing)

Gli Spyware sono usati per il furto di credenziali, identità o informazioni sensibili; normalmente lo Spyware è installato su un computer con l'intento di monitorare le varie attività svolte, come accedere allo storico e ai contenuti dei browser, ridirezionare richieste web verso pagine false controllate dall'hacker. Un caso particolare di spyware, peraltro molto utilizzato, è il cosiddetto Phishing che consiste nell'uso di spam e-mail per indurre l'utente a compilare dei form con password e dati personali (furto d'identità).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2.7 Bot (robot), Zombie

I Bot (Zombie) attaccano le risorse computazionali e di rete che diventano di dominio dell'hacker; dal computer infetto (di solito insospettabile) il Bot si collega ad un altro computer in rete per lanciare o gestire un attacco. I Bot sono installati su un grande numero di computer quindi è difficile risalire all'hacker sorgente dell'attacco, inoltre i Bot possono agire in maniera coordinata (botnet) e possono essere controllati da remoto (questa è la caratteristica che li distingue dai worm che invece si propagano e attivano da soli). Solitamente le botnet possono usare il protocollo HTTP per comunicare e attraverso questo un modulo di controllo centrale è in grado di inviare comandi ai bot, come fare il download di un file, eseguire un file, inviare altri malware, ecc.

2.8 Spam

Con il termine Spam (Spammer) si intende l'invio massivo di e-mail agli indirizzi di potenziali vittime; esso genera volume di traffico sull'infrastruttura di rete e costringe i destinatari a filtrare la posta in arrivo. L'invio può avvenire da server di posta o da botnet che usano sistemi compromessi; tale problematica si è ultimamente spostata anche sulle reti di media sociali. Lo spam è veicolo di malware ed è usato per il phishing.

2.9 Exploit

Con il termine Exploit si intende del codice specifico per sfruttare una particolare lacuna di sicurezza. Un esempio classico riguarda alcune vulnerabilità presenti nei browser: l'utente visita una pagina web controllata da un hacker, la pagina usa tale lacuna per installare un malware nel sistema dell'utente. Un altro caso invece, riguarda l'uso di malware in forma indiretta: in questo caso si cercano vulnerabilità su dei siti web visitati dagli utenti che si vogliono attaccare; il codice addirittura può anche essere scritto per non infettare altri utenti che si trovano a vistare tali siti.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- *Malvertising è un esempio simile: l'hacker espone pubblicità che incorpora un malware su un sito web legittimo*
- *Clickjacking sfrutta le vulnerabilità per catturare un click dell'utente (bottone con un livello trasparente) al fine di inviarlo su una pagina infetta*

2.10 Ransomware

Il Ransomware è un malware che cifra i dati dell'utente e richiede un pagamento (riscatto) per rivelare la chiave di decifratura per recuperare i file

Esistono inoltre altri malware che come azione (il cosiddetto payload)

- *cancellano i file dell'utente vittima*
- *modificano il codice BIOS per impedire l'avvio del computer (in questo caso si parla di danno fisico).*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Attacchi DDoS

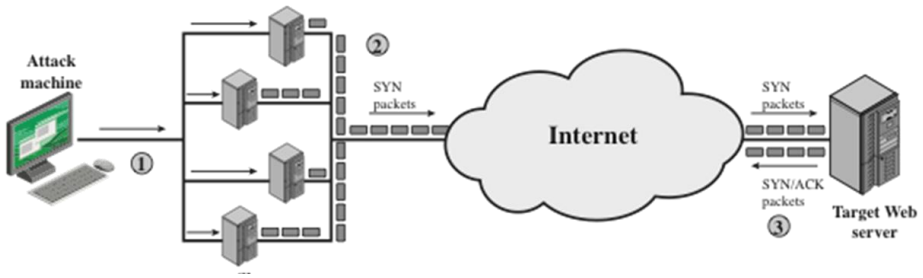
Un attacco *DDoS (Distributed Denial of Service)* tenta di impedire a dei legittimi utenti di un servizio l'accesso a tale servizio; due sono sostanzialmente le modalità di danno arrecato:

- consumo di risorse interne (server)
- consumo di risorse di rete (capacità della rete)

L'attacco DDoS rende un sistema inaccessibile inondando i server, la rete e i terminali con traffico inutile; se l'attacco proviene da un unico computer si parla di DoS, quando invece si usano un gran numero di host compromessi si parla appunto di DDoS.

L'attacco *SYN flood* è un esempio di attacco ad una risorsa interna, di seguito sono elencate le varie fasi:

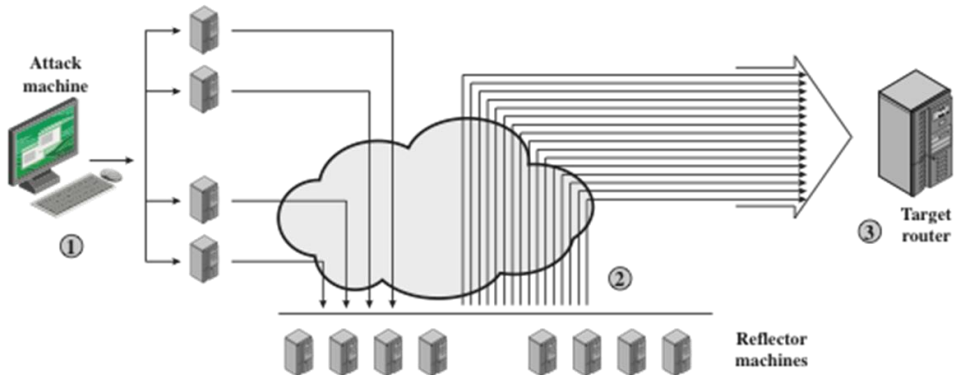
1. L'attaccante prende controllo di un certo numero di host (slave)
2. Gli slave host sono istruiti ad inviare al target server pacchetti di TCP/IP SYN (sincronizzazione/inizializzazione) con indirizzo di ritorno errato
3. Il server risponde a ciascuno con un pacchetto SYN/ACK ad un indirizzo fasullo e resta in attesa di una risposta che non arriva
4. Il server alla fine non è più in grado di soddisfare le richieste legittime



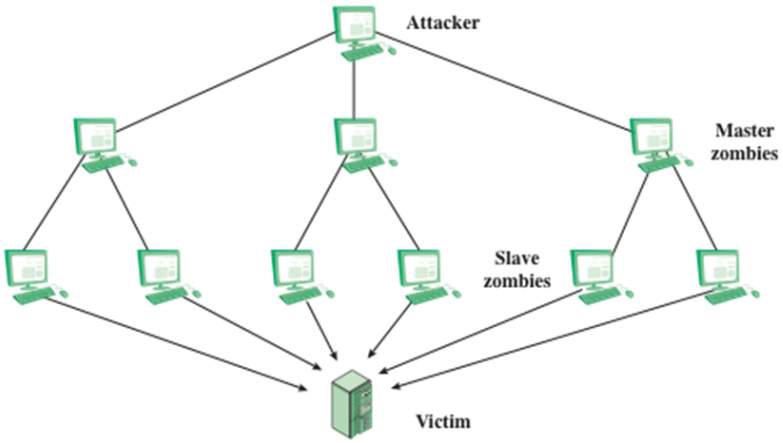
L'attacco *ICMP (Internet Control Message Protocol)* è invece un esempio di attacco alle risorse di capacità trasmissiva e utilizza delle macchine con funzione di "riflettori". L'hacker in

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

questo caso prende il controllo di vari host su Internet (riflettori) e li programma per inviare dei pacchetti ICMP ECHO con indirizzo IP falsificato ed uguale a quello della macchina da attaccare. Il protocollo ICMP è un protocollo a livello IP per lo scambio di pacchetti di controllo tra un server (host) e un host; tale protocollo prevede che il ricevente invii una risposta (ECHO REPLY) all'indirizzo del mittente che in questo caso è appunto quello della macchina target. La macchina target risulta così inondata di messaggi.



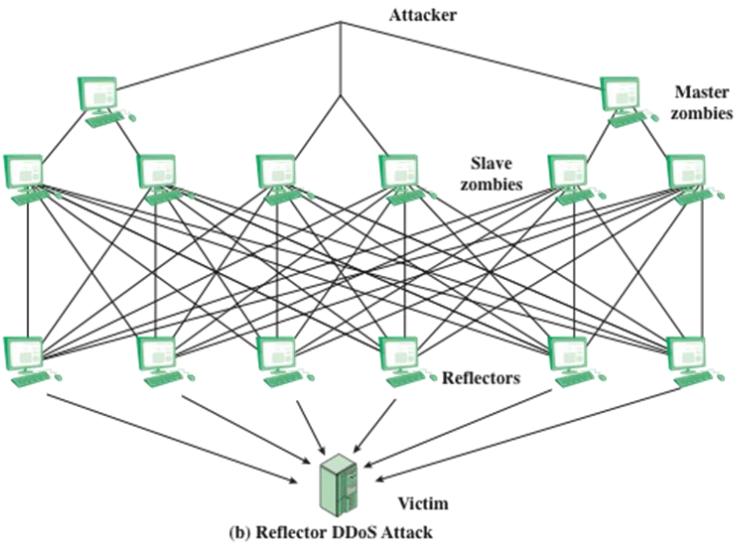
L'attacco DDoS può anche essere classificato in *DDoS diretto* o *DDoS riflettore*. Si parla di DDoS diretto quando l'attaccante usa degli zombie per infettare della macchine in una struttura gerarchica da cui lanciare un attacco coordinato di DDoS (vedi figura sottostante).



(a) Direct DDoS Attack

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Si parla invece di DDoS riflettore quando gli host slave costruiscono pacchetti che richiedono una risposta diretta verso l'indirizzo IP del sistema target. Tali pacchetti sono inviati a macchine non infette che funzionano da riflettori (vedi figura sottostante). In tal caso diventa molto difficile risalire fino alla sorgente.



(b) Reflector DDoS Attack

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: *Capitolo 19.*

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).